SIMATS ENGINEERING

ITA14 – ETHICAL HACKING

ASSIGNMENT 1 – CO1

Design and Develop a Complete Ethical-Hacking Engagement Framework

for a University's Authorized Security-Assessment Programme

Total Marks: 50

Scenario and Problem Statement

A university plans to assess the security of its student portal, learning-management system, email service and campus network before a major upgrade. The initial programme covers approximately 20 systems and 50 staff, with future expansion to the whole university and external third-party assessors. Assessments may involve personal data. The university needs governance that prevents unauthorized access, legal exposure, service damage, scope confusion and uncoordinated vulnerability disclosure.

The framework below is a governance and design deliverable. It does not authorize testing of real university systems. All practical examples are restricted to an isolated lab with intentionally designated targets. No live exploitation is performed.

Source alignment: the assignment's stated requirements and task order are followed. Where the brief does not supply operational facts, assumptions are labelled and the university must approve them before implementation.

Student Details	Information
Student Name	Balaji Rohith MV

Register Number	192521269
Department / Section	B.Tech Information Technology
Academic Year / Semester	2026
Faculty Name	Dr. Parthiban
Date of Submission	31.10.2026

Total Marks 50

Executive Summary

The proposed framework uses a mandatory authorization gate, explicit asset scope, a written Rules-of-Engagement (RoE), legal and privacy review, a controlled isolated lab, reusable engagement documents, and coordinated vulnerability disclosure. Each engagement receives a unique identifier linking its request, approval, scope, test evidence, findings, remediation and closure. Testing cannot begin until the asset owner and designated university authority have signed the scope and the legal/privacy checks are complete.

The framework distinguishes three separate questions: (1) Is the activity authorized by the system owner? (2) Is it lawful under applicable law and institutional obligations? (3) Is it appropriate under university policy and professional ethics? All three conditions must be satisfied.

TASK 1 – Formulate the Enquiry and Framework Blueprint

1.1 Governance requirements

Requirement ID	Requirement	Governance response / acceptance evidence

G-01	Identify assets and accountable owners.	Asset register with system name, owner, environment, data classification and approved address/identifier.
G-02	Obtain valid written authorization before any test.	Signed authorization form naming tester, systems, dates, methods and approver.
G-03 G-04	Define boundaries and prohibited actions. Respect applicable law and personal-data obligations.	RoE with in-scope/out-of-scope list, test window, rate limits, stop conditions and escalation contacts. Legal/privacy review recorded against each engagement; minimisation and secure evidence handling.
G-05	Model relevant threat actors.	Consistent actor classification using motivation, capability, access and target.
G-06	Use safe testing environment where hands-on validation is required.	Host-only lab, documented IP plan, snapshots and connectivity checks.
G-07	Handle vulnerabilities responsibly.	Secure reporting, severity triage, remediation owner, deadline, retest and closure record.
G-08	Support internal and external assessors.	Named accounts, confidentiality obligations, least privilege, supervision and access expiry.
G-09	Maintain auditability and scalability.	Unique engagement ID, immutable approval/status log, standard templates and

		metrics.

1.2 Stakeholders and responsibilities

Stakeholder	Responsibility
Executive sponsor / CISO	Owns programme policy, risk acceptance and escalation.
System / asset owner	Confirms ownership, business criticality, scope and maintenance window.
Legal and privacy officer	Reviews statutory, contractual and personal-data implications.
Engagement manager	Creates engagement record, coordinates approval, RoE, schedule and evidence.
Authorized tester	Works only within signed scope; protects data and reports findings accurately.
IT operations / incident response	Monitors service health, supports stop conditions and handles incidents.
Vulnerability owner / developer	Remediates finding, provides fix evidence and coordinates retest.
External assessor	Meets equivalent authorization, confidentiality, access and evidence-handling rules.

1.3 Enquiry questions

- Who has authority to approve testing of each asset, and how is that authority verified?
- Which systems, IP ranges, accounts, dates and techniques are explicitly in scope?
- Which Indian legal and privacy requirements apply when personal data may be

encountered, and what additional contractual obligations exist?

- How are findings validated, severity-rated, assigned, remediated and disclosed without exposing users?
- How can the university demonstrate that external assessors follow the same rules as internal testers?

1.4 Design criteria / acceptance criteria

Criterion	Acceptance test
Authorization completeness	No test can start without signed approval, asset owner confirmation and valid dates.
Scope precision Legal and privacy review	Every target is identified by a stable asset ID/address; unknown targets are blocked. Personal-data touchpoints have recorded review, minimisation and secure evidence rules.

Safety	Lab is isolated; production testing has explicit windows, rate limits and stop conditions.
Disclosure accountability	Every finding has owner, severity, remediation target date, status and closure evidence.
Auditability	All approvals and status changes carry timestamp, actor and engagement ID.
Scalability	Templates and workflow can be reused for multiple departments and third-party assessors.

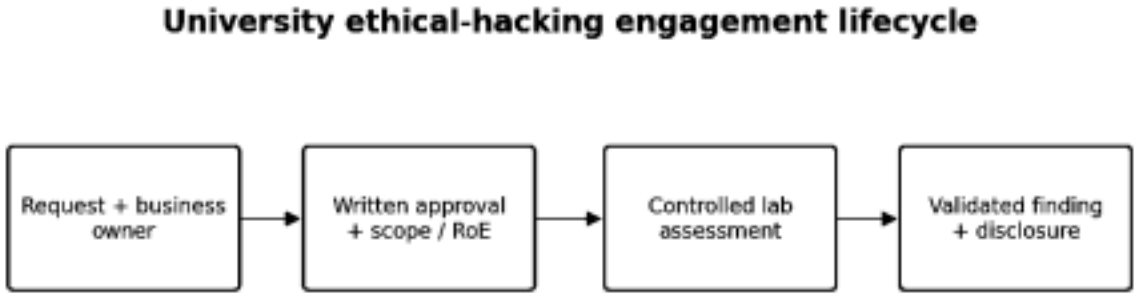


Figure 1. End-to-end engagement lifecycle with mandatory governance gates.

TASK 2 – Design a Hacker Threat Model and Classification

The framework classifies actors by observed behaviour and evidence, not by appearance or unsupported assumptions. Motivation and capability are separate dimensions: a technically skilled actor is not automatically malicious, and a person claiming good intent is not automatically authorized.

Actor class	Typical motivation	Capability / access	Likely university targets
White-hat	Improve security under authorization.	Professional skills; written scope and permission.	Student portal, LMS, email, campus network.
Black-hat	Financial gain, theft, disruption or coercion.	May use malware, credential theft, exploitation or persistence.	Student records, payment systems, research data.
Grey-hat	Curiosity, recognition or disclosure without clear permission.	May find weaknesses but act outside authorization.	Public-facing portals, exposed services.
Script kiddie	Experimentation, status or opportunism.	Uses public tools and copied scripts; skill varies.	Weakly configured services and exposed login

			pages.
Hacktivist	Political/social cause, protest or publicity.	Defacement, DDoS, data leaks or account compromise.	University website, public communications, events.
Insider	Grievance, financial benefit, coercion or accidental misuse.	Legitimate access that may be misused or over-privileged.	Student information, HR/email, admin consoles.
State-sponsored	influence.	targeted.	property, accounts,
Strategic intelligence, research theft or	Potentially persistent, resourced and	Research intellectual	sensitive networks.

2.1 Consistent classification criteria

● Authorization: documented permission, no permission, or unclear permission. ● Intent: defensive improvement, curiosity, financial gain, disruption, espionage or unknown.

- Capability: basic tool use, intermediate exploitation, advanced tradecraft or unknown.
- Access: external unauthenticated, authenticated user, privileged insider or supplier access.
- Observed behaviour: scope compliance, data access, persistence, concealment, disruption or responsible reporting.

2.2 Borderline actor example

Example: a student discovers an exposed directory on a university website and downloads a small sample of records to prove impact, without first obtaining permission. The student then emails the IT team.

Possible classification	Reason it could fit	Limitation
Grey-hat	The person may claim curiosity and intends to notify the university.	The download was outside authorization and may have exposed personal data.
Black-hat / unauthorized actor	Accessing or copying data without permission can be harmful and legally significant regardless of claimed motive.	Malicious intent is not established by the facts alone.

Final framework classification: record the event as an unauthorized security incident with an actor whose intent is unconfirmed; do not grant the person white-hat status. This operational classification avoids guessing motive and triggers evidence preservation, privacy review and incident handling. The actor can be reclassified if reliable evidence emerges.

2.3 Rejected alternatives

A motivation-only label such as 'good hacker' or 'bad hacker' is rejected because it ignores authorization and actual conduct. A skill-only label is rejected because capability does not establish intent. The final model records authorization, behaviour, motivation and capability separately.

TASK 3 – Create an Ethics and Code-of-Conduct Module

Principle	Required conduct	Preventive check
Written authorization	Do not test until signed permission is recorded.	Approval ID, named approver, assets, dates and tester identity verified.
Scope discipline	Use only listed assets and methods.	Target allow-list; out-of-scope request triggers stop and

		escalation.
Avoid harm	Use safe rates; avoid destructive actions and unnecessary data access.	Test limits, monitoring, stop conditions and approved maintenance window.
Confidentiality	Protect credentials, personal data, screenshots and logs.	Encryption, redaction, restricted repository and retention schedule.

Integrity Do not alter records or systems except where explicitly	approved. Read-only preference, change log, backups and evidence	hashes.

Honest reporting	Describe method, limitations, impact and uncertainty accurately.	Peer review; distinguish verified findings from hypotheses.
Responsible disclosure	Notify the designated university contact privately.	Secure channel, acknowledgement, remediation plan and disclosure decision.

3.1 Decision rules

- If authorization is absent, expired or ambiguous: STOP; no probing is permitted.
- If a target is not on the signed scope list: STOP and request a scope amendment.
- If personal data is encountered: minimise access, do not copy more than needed, secure the evidence and notify the engagement manager/privacy contact.
- If service degradation, unexpected access or data exposure occurs: stop immediately and activate the escalation path.
- If a finding cannot be reproduced safely: report it as unverified, with limitations, rather than escalating testing beyond scope.

3.2 Scenario test cases

Case	Action	Classification	Code response
A	Tester checks an approved lab target during signed window using approved low-impact scan.	Acceptable	Log activity and retain minimal evidence.
B	Tester wants to check a neighbouring IP not listed in scope.	Unacceptable until amended	Block target; request written scope change.
C	Tester sees personal records in an exposed response and captures the entire database.	Unacceptable	Stop; secure minimal proof; privacy and incident escalation.
D Tester proposes a higher-rate scan to finish sooner, without approval.	Borderline / not permitted	Obtain approval and assess service impact before any change.	
E	Tester reports a verified weakness privately with reproducible evidence and remediation advice.	Acceptable	Create finding record and begin coordinated disclosure.

The code preserves trust by making authority, safety, confidentiality and honesty observable through checks and logs rather than relying only on personal judgement.

TASK 4 – Construct a Legal-Compliance Mapping

This is an educational mapping for the scenario, not legal advice. The university must obtain current advice from qualified counsel before authorizing a real engagement.

The assignment specifically asks for the Indian Information Technology Act, 2000 and comparison with the United States Computer Fraud and Abuse Act (CFAA). Applicability depends on facts, jurisdiction, data, contracts and the law in force at the time.

Legal area	What it addresses at a high level	Framework control
India IT Act, 2000 – Section 43	Certain unauthorized access, copying, disruption and related acts can attract civil liability/compensation.	Written authorization; exact scope; no copying or disruption beyond approved test.
India IT Act, 2000 – Section 66	Computer-related acts described under Section 43 when done dishonestly or fraudulently may attract criminal consequences.	Authorization gate; identity verification; activity logs; stop conditions.
India IT Act, 2000 – Section 72	Breach of confidentiality and privacy by a person who has obtained access under powers conferred by the Act, subject to statutory elements.	Confidentiality undertaking; least-privilege evidence access; restricted reporting.
India IT Act, 2000 – Section 72A	Disclosure of information in breach of lawful contract, subject to statutory elements.	Contractual confidentiality, data processing terms, controlled evidence repository.
Personal-data obligations	The applicable Indian data-protection regime and rules may impose duties when	Privacy review, purpose limitation, minimisation,

	personal data is processed; applicability and commencement/transitional provisions must be checked	access controls, retention and breach escalation.

	for the engagement date.	
US CFAA – 18 U.S.C. §1030	Federal offences concerning unauthorized access or exceeding authorized access to protected computers, among other conduct.	For US-connected systems or actors, obtain jurisdiction-specific counsel; define authorization and scope precisely.

4.1 Offences, obligations and penalties – comparison

Provision	Illustrative legal consequence / obligation	Important qualification
IT Act §43	Compensation may be payable for specified unauthorized acts such as access, copying or disruption.	Civil liability; exact facts and statutory wording govern.
IT Act §66	Where the §43 acts are done dishonestly or fraudulently, punishment may include imprisonment up to 3 years or fine up to ₹5 lakh, or both.	Confirm current amended text and facts with counsel.
IT Act §72	Breach of confidentiality/privacy by a person acting under powers conferred by the Act may attract imprisonment up to 2 years, fine up to ₹1 lakh, or both.	The statutory elements are specific; not every confidentiality breach automatically falls under §72.

IT Act §72A	Disclosure of personal information in breach of lawful contract, with required wrongful/loss elements, may attract imprisonment up to 3 years or fine up to ₹5 lakh, or both.	Assess contract, intent and statutory conditions.
CFAA §1030	Depending on offence category, penalties vary and may include fines and imprisonment; some provisions also permit civil actions.	US jurisdiction, protected-computer definition, authorization and applicable subsection matter.

Important legal caution: statutory wording, amendments, rules and commencement dates can change. The framework therefore requires a dated legal review for every engagement rather than treating this table as a complete legal opinion. Where student or staff personal data may be encountered, privacy review is mandatory before testing; data should not be copied merely to demonstrate impact.

4.2 Application to personal-data systems

The student portal, LMS and email service may contain personal data. The engagement manager must identify data categories, purpose, access path, data controller/processor roles where relevant, retention needs, cross-border access and contractual obligations. Testers should use synthetic accounts and synthetic data in the lab wherever possible. In production, the RoE must prohibit bulk extraction and require immediate escalation if real personal data is exposed.

The CFAA is not automatically applicable to a university in India. It becomes relevant only where the facts establish a US jurisdictional connection, such as a protected computer or conduct within the statute's reach. Counsel must determine applicability; the university should not assume that an international comparison

creates jurisdiction.

TASK 5 – Create a Scope and Rules-of-Engagement Document

5.1 Reusable RoE template

Field	Required content / example
Engagement ID	EH-YYYY-### (unique and non-reusable).
Business purpose	Assess approved security controls before the university platform upgrade.
Authorizing authority	Named university official with delegated authority; approval evidence attached.
Asset owner	Department and named owner for each target.
In-scope systems	Explicit asset IDs, hostnames, IP addresses, environment and application endpoints.
Out-of-scope	All unlisted IPs/domains, third-party systems, production data stores unless expressly

	approved, personal devices and campus-wide scanning.
Tester identity	Names, organization, account IDs, supervisor and contact details.
Window	Start/end date, local time zone, maintenance window and blackout periods.
Permitted methods	Approved discovery, configuration review, authenticated checks and non-destructive validation listed individually.

Prohibited methods	Denial-of-service, destructive payloads, persistence, credential harvesting, social engineering, bulk data extraction, lateral movement and testing third parties unless specifically authorized.
Safety limits	Rate limits, concurrency caps, test accounts, data minimisation and service-health monitoring.
Stop conditions	Unexpected data exposure, service degradation, out-of-scope access, incident alert, expired approval or owner request.
Escalation	Engagement manager, asset owner, SOC/incident response, privacy officer and legal contact.
Evidence handling Sign-off	Encryption, access list, redaction, retention period, deletion confirmation and evidence hashes. Approver, asset owner, tester and privacy/legal reviewer where required; dates and signatures.

5.2 Authorization verification rules

- Verify the approver's identity and delegated authority through the university directory or governance office.
- Confirm the signature is linked to the exact engagement ID and latest RoE version.
- Match every target to the asset register and obtain third-party permission where applicable.
- Check that approval dates cover the planned test window and have not been revoked.
- Record a cryptographic hash or controlled version identifier for the signed

document.

- If any field is missing or inconsistent, mark the engagement BLOCKED; verbal permission is not sufficient.

5.3 Derived pre-engagement checklist

Check	Pass condition	Status
Authorization	Signed by authorized approver and asset owner.	[ ]
Scope	Targets match asset IDs, IPs and approved environment.	[ ]
Legal/privacy	Review complete; personal-data controls documented.	[ ]
Tester	Identity, confidentiality terms and access expiry verified.	[ ]
Schedule	Window, contacts, blackout periods and monitoring agreed.	[ ]
Methods Safety	Permitted/prohibited limits understood.	and deletion plan ready. [ ] [ ] [ ]
Evidence techniques and rate	Stop conditions, backup/restore and escalation tested. Secure storage, redaction, retention	

The checklist is derived directly from the RoE fields. It is not a separate authorization: the signed RoE remains the controlling document.

TASK 6 – Build an Authorization and Disclosure Layer



Figure 2. Authorization workflow. The test window opens only after all required approvals are recorded.

6.1 Authorization workflow

1. Request: department submits business purpose, asset list, data classification, proposed methods and requested dates.
2. Ownership validation: engagement manager confirms the asset owner and third-party dependencies.
3. Risk and legal review: security, privacy and legal reviewers assess data exposure, safety, jurisdiction and contract conditions.
4. Scope and RoE: manager generates versioned scope and prohibited-action list; tester acknowledges it.
5. Written approval: authorized official and asset owner sign; required privacy/legal sign-offs are attached.
6. Registration: system creates engagement ID and immutable approval/status entries.
7. Pre-flight: checklist passes, accounts and lab are ready, and operations contacts confirm monitoring.
8. Execution: engagement manager opens the window; tester records actions against the engagement ID.
9. Closure: evidence is secured, access is revoked, findings are assigned and final report is approved.

6.2 Coordinated vulnerability disclosure process

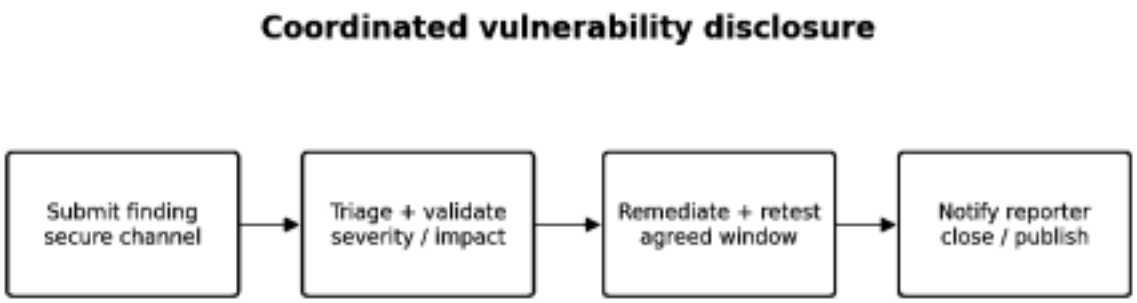


Figure 3. Coordinated disclosure protects users while giving the owner a reasonable remediation opportunity.

Stage	Target service level (proposed)	Required record
Acknowledgement	Within 2 business days of report receipt.	Ticket ID, reporter contact, date and secure channel.
Triage	Within 5 business days; faster for critical exposure.	Validity, affected assets, severity, exploitability and data impact.
Remediation plan	Within 10 business days for ordinary findings; immediate containment for active critical exposure.	Owner, mitigation, target date and risk acceptance if applicable.
Retest	After fix or mitigation is deployed.	Reproduction steps, retest result and residual risk.
Closure / disclosure decision	Review at least every 30 days until closure; publication only after coordinated decision.	Approvals, redactions, disclosure date and final status.

These are proposed programme targets, not statutory deadlines. Critical or actively exploited issues require immediate containment and escalation; the university may shorten targets based on risk.

6.3 Comparison of disclosure approaches

Approach	Advantages	Risks / limits	Use in this framework
Coordinated disclosure	Allows validation, remediation and user protection before public detail.	Can be delayed if owner does not respond; requires trusted process.	Default for university findings.
Full disclosure	Can alert users and pressure an unresponsive owner.	May enable exploitation before a fix; exposes system details and personal data risk.	Exceptional; only after legal, privacy and safety review and a documented decision.
Bug bounty	intake.	triage capacity.	funding are ready.
Provides structured external reporting and incentives; scalable	Requires clear scope, duplicate handling, payment rules and	Optional future programme after governance and	

6.4 Logging and decision operations

Operation	Input	Output / control
CreateEngagement	Request, owner, target list and purpose.	Engagement ID; status REQUESTED.
ApproveEngagement	Signed authorization and reviews.	Status APPROVED; approver identity, timestamp and document version.
OpenTestWindow	Approved RoE, checklist and schedule.	Status ACTIVE; time-bounded tester access.
RecordFinding	Finding report, evidence reference and asset ID.	Finding ID; severity; owner; disclosure clock starts.
UpdateFinding	Status, mitigation, retest and approval.	Append-only status history.

AuthorizeDisclosure CloseEngagement	Remediation state, legal/privacy review and risk decision. Final report, access revocation and evidence disposition.	COORDINATED / DEFERRED / EXCEPTIONAL PUBLIC decision with rationale. Status CLOSED; closure checklist.

Interaction rule: authorization controls whether testing may start; the RoE limits what may be done; legal/privacy review constrains data handling; the disclosure layer governs how findings leave the restricted programme. A finding cannot be publicly disclosed merely because it exists.

TASK 7 – Design an Isolated Ethical-Hacking Lab

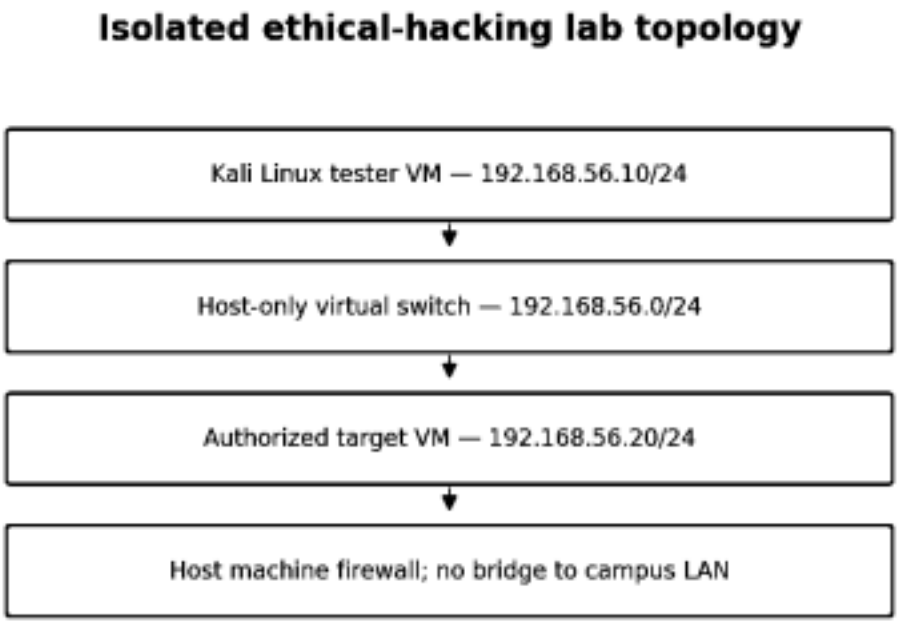


Figure 4. Host-only lab topology using a reserved private subnet. No route to the campus network is configured. **7.1**

Components and roles

Component	Example configuration	Role
Host computer	Hypervisor such as VirtualBox/VMware; host firewall enabled.	Runs and isolates virtual machines.

Kali Linux VM	192.168.56.10/24; no bridged adapter.	Authorized tester workstation and approved tools.
Target VM	192.168.56.20/24; intentionally vulnerable lab image or university-owned test image.	Authorized target for controlled exercises.
Virtual network	Host-only network 192.168.56.0/24; no default gateway.	Allows VM-to-VM traffic without campus LAN exposure.

Evidence storage	Encrypted host folder, access restricted to engagement team.	Stores configuration, logs and sanitized findings.

7.2 Setup and verification operations

10. Create a host-only virtual network with subnet 192.168.56.0/24 and disable bridging to physical adapters.
11. Attach Kali and the target VM only to that host-only network; assign 192.168.56.10 and 192.168.56.20 respectively.
12. Take clean snapshots and record VM names, image hashes, adapter type, MAC addresses, IP addresses and date.
13. From Kali, verify local interface configuration with `ip addr` and routes with `ip route`.
14. Verify target reachability with `ping -c 4 192.168.56.20` where ICMP is enabled; record the result.
15. Verify that no route exists from the lab to campus/Internet networks and that the host firewall blocks unintended forwarding.
16. After testing, export sanitized logs, restore snapshots if required and remove

temporary accounts/access.

7.3 Safe lab operations

```
# Kali VM: record interface and route configuration
ip addr
ip route

# Connectivity check to the authorized lab target only
ping -c 4 192.168.56.20

# Record route and interface details for the engagement evidence
ip -br addr
ip -s link

# Example: hash a saved configuration/evidence file
sha256sum lab-network-notes.txt
```

7.4 Host-only versus NAT

Property	Host-only network	NAT network
VM-to-VM communication	Yes, on the private host-only segment.	Usually yes, depending on virtual network configuration.
Access from guest to Internet	No by default.	Usually allowed through host NAT.
Inbound reachability from campus LAN	No by default; depends on host routing/firewall.	Not directly by default; port forwarding can expose services.
Containment	Strong choice for a closed lab when host routing is disabled.	More convenient for updates but introduces an outbound path.
Recommended use this assignment.	Primary testing network for	Optional temporary update network, disabled during assessment.

Host-only is selected because the brief requires an isolated environment. If updates are needed, use a separate controlled maintenance phase and disconnect NAT before testing. Never bridge the lab to the campus network.

TASK 8 – Develop a Reusable Document Library

The following four templates are reusable components. All documents use the same Engagement ID and Asset ID fields so records can be joined and audited.

8.1 Document A – Authorization request and approval form

Field	Description / validation
Engagement ID	System-generated unique ID; cannot be reused.
Requesting department / business purpose	Mandatory; concise and specific.
Asset owner and approver	Mandatory names, roles and verified authority.
Target assets	Mandatory asset IDs, hostnames/IPs and environment.
Testing methods and window	Mandatory; dates, time zone and allowed techniques.
Data classification / personal data	Mandatory declaration; privacy review if personal data may be encountered.
Third-party dependencies	List each supplier/system and attach permission.

Signatures and dates Approver, owner and tester acknowledgement; valid date range.

Decision	PENDING / APPROVED / REJECTED / EXPIRED.

8.2 Document B – Rules of Engagement and pre-flight checklist

Contains scope boundaries, allowed and prohibited techniques, rate limits, test accounts, stop conditions, emergency contacts, evidence handling, schedule and required sign-offs. The checklist is generated from these fields and cannot override the signed RoE.

8.3 Document C – Finding report

Field	Structured value / purpose
Finding ID	Unique ID linked to Engagement ID.
Asset ID / affected component	Must match approved asset register.
Title and description	Clear, factual summary.
Severity	Critical / High / Medium / Low / Informational; include scoring method.
Evidence reference	Restricted file pointer and SHA-256 hash; redact personal data.
Reproduction conditions	Only safe, approved steps in lab or explicitly authorized scope.
Impact and likelihood	Confidentiality, integrity, availability and business impact.
Recommendation	Practical mitigation and priority.
Owner / due date / status Disclosure classification Retest / closure	Assigned remediation owner and tracked lifecycle. Coordinated / deferred / exceptional decision; approval reference. Retest evidence, residual risk and closure approver.

8.4 Document D – Coordinated disclosure and closure log

Field	Description
Finding ID / Engagement ID	Join keys to finding and engagement.
Reporter / contact	Restricted identity and secure contact route.
Acknowledgement / triage timestamps Severity and affected users Remediation plan / due date Status history	Measures response time. Risk basis for remediation priority. Owner, mitigation and agreed timeline. Append-only updates with actor and timestamp.

Disclosure decision	Decision, approver, rationale and redactions.

Closure	Retest result, notification and evidence disposition.

8.5 Test entries and validation

Input test	Example	Expected result
Valid	Signed approval, current dates, named owner and exact lab target.	APPROVED after all reviews; test window may open.
Boundary	Scope contains 192.168.56.20 but tester requests 192.168.56.21.	Request blocked; scope amendment required.
Invalid	No owner signature or approval date expired.	REJECTED / BLOCKED; no testing.
Invalid personal-data handling	Finding attachment contains unredacted student records.	Upload blocked or quarantined; privacy escalation and sanitized replacement required.
Valid finding	Finding includes approved Asset ID, evidence hash, severity, owner and remediation date.	Finding ID created and disclosure workflow initiated.

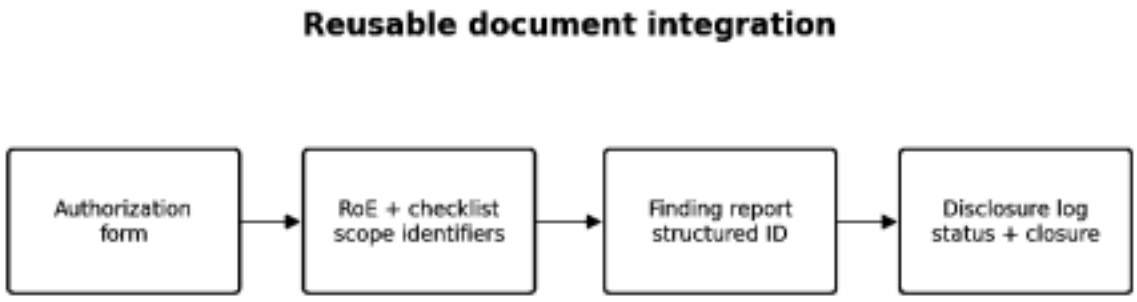


Figure 5. Document library joins authorization, scope, findings and disclosure through stable identifiers.

TASK 9 – Integrate, Test and Refine the Framework

9.1 Integrated walkthrough

17. A department requests assessment of its LMS test environment and identifies the asset owner and business purpose.
18. The engagement manager creates EH-2026-001 and checks asset ownership, data classification and third-party dependencies.
19. Legal/privacy review confirms that the test environment uses synthetic student records and documents any remaining obligations.
20. The owner and authorized university approver sign the authorization form and versioned RoE.
21. The pre-flight checklist verifies tester identity, target allow-list, test window, lab isolation, stop conditions and evidence storage.
22. The tester performs only the approved checks against the isolated target; activity and evidence references are logged.
23. A finding is submitted using the structured report, validated by the engagement manager and assigned to the system owner.
24. The owner applies a fix; the tester performs an approved retest; the disclosure layer records remediation and communication.
25. Access is revoked, evidence is retained or deleted under policy, and the engagement is closed.

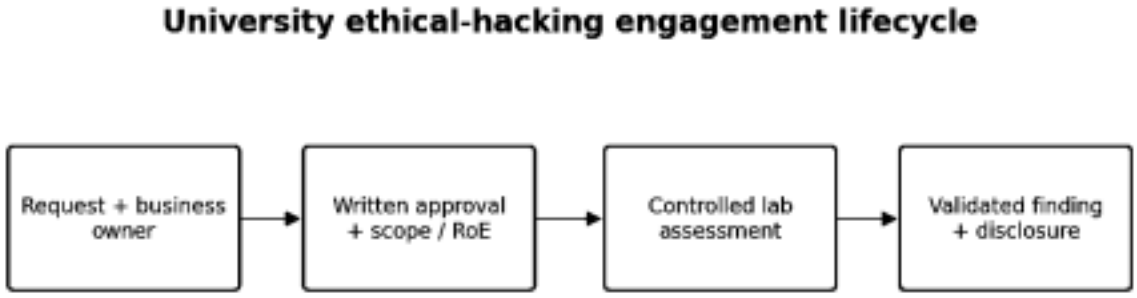


Figure 6. The walkthrough uses one engagement ID from request through closure.

9.2 Systematic test cases

Test case	Injected condition	Expected framework response
TC-01 Missing authorization	Request has no signed approver form.	BLOCKED; test window cannot open.
TC-02 Out-of-scope target	Tester selects an address not in approved list.	STOP; log event; require signed scope amendment.
TC-03 Legal/privacy conflict	Target may expose live personal data but privacy review is absent.	BLOCKED pending legal/privacy decision; use synthetic data/lab.
TC-04 Delayed disclosure	Remediation target date passes without owner update.	Escalate to CISO/programme owner; record revised plan and risk.
TC-05 Expired approval	Test date is later than authorization expiry.	Target resolves to Access disabled; new approval required.
TC-06 Unexpected impact occurs during testing.	Service health alert	Stop immediately; incident response and owner notified. Exclude target until written
TC-07 Third-party dependency	supplier-owned service without permission.	supplier authorization is attached.

9.3 Refinements after walkthrough

Issue observed in design review	Refinement
Approval may be separated from a later RoE version.	Bind approval to a version/hash of the RoE; any scope change requires reapproval.
Personal-data exposure may not be immediately visible to tester.	Add mandatory data-minimisation rule, stop trigger and privacy contact to pre-flight checklist.
External tester access may remain active after engagement.	Use time-limited accounts and automated revocation at closure or expiry.
Finding report may omit asset identity or remediation owner.	Make Asset ID, Engagement ID and owner mandatory structured fields.
Disclosure delay may go unnoticed.	Add deadline monitoring, escalation and a documented exception decision.

TASK 10 – Create a Scalability and Governance Evaluation

The brief asks for small and large programme scenarios and measures across at least three processes. The figures below are planning assumptions used to demonstrate the evaluation method, not observed university performance. Replace them with timed walkthrough results when the framework is piloted.

Measure	Small programme assumption	Large programme assumption	Governance implication
Programme scale	1 department; 20 systems; 5 testers.	Whole university; 200 systems (planning scenario); 50 staff/testers including external assessors.	Central asset register and role-based workflow become necessary.

Approval workflow steps	6 steps with one owner and one approver.	8 steps with asset owner, central security, privacy/legal and third-party checks.	Use risk-tiered approval routing while retaining mandatory gates.
Approval turnaround target Scope coverage Disclosure tracking	3 business days for low-risk lab engagement. One system owner validates all listed assets. One finding owner and one reviewer.	5 business days for routine multi-department engagement; urgent path for critical risk. Multiple owners validate asset subsets; external dependencies increase. Multiple remediation teams, suppliers and reporters.	Track queue time and escalation; do not bypass sign-off. Automate asset matching and reject unknown targets. Use shared finding IDs, SLA alerts and central status dashboard.

10.1 Three process experiments

Process	Measure	How to run the evaluation
Authorization	Elapsed business time from complete request to signed approval; number of handoffs.	Run 5 sample requests; record submission, review, approval timestamps and rework count.
Scope validation	Percentage of requested targets matched to approved asset register; number of out-of-scope detections.	Create a test list with valid, unknown and third-party assets; measure correct allow/block decisions.
Disclosure	Time to acknowledge, triage and assign owner; number of overdue transitions.	Use simulated findings with different severities; measure workflow timestamps and escalation.

10.2 Example structured visualization

Illustrative process-step comparison only: small programme = 6 approval steps; large programme = 8 steps. This is a planning model derived from the assumed governance roles above, not an experimental measurement.

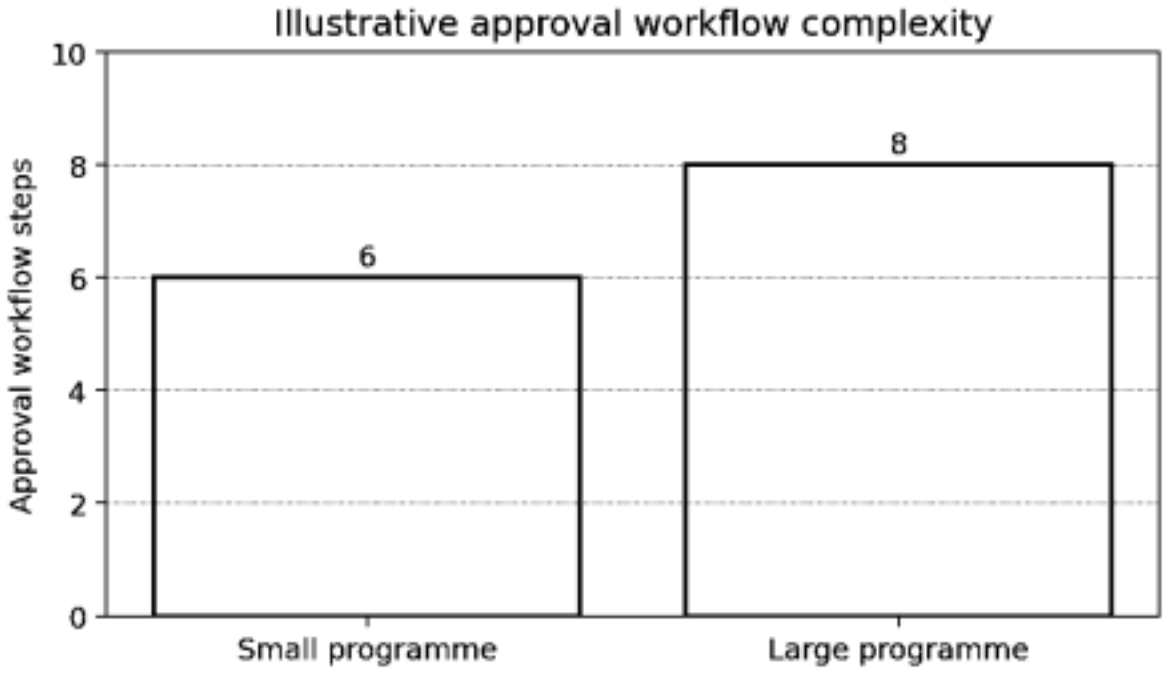


Figure 7. Illustrative governance complexity. Replace planning assumptions with measured pilot data.

10.3 Governance refinement based on evaluation

As the programme expands, use a central security programme office to maintain templates, engagement IDs, asset inventory, disclosure status and audit logs. Departmental asset owners retain responsibility for approving their systems. External assessors receive time-bound, least-privilege access after identity and contract checks. Low-risk lab-only work may use a streamlined review route, but legal/privacy checks and written authorization are never removed when required.

TASK 11 – Defend the Framework Under a Changed Requirement

11.1 Changed requirement analysis

The programme now includes continuous and third-party assessments, stricter data-protection requirements and shorter disclosure timelines. A one-time manual approval process would become slow and inconsistent. At the same time, continuous testing must not become blanket authorization: every activity still needs a valid, bounded authorization and current scope.

11.2 Retain, modify, replace or redesign

Component	Decision	Reason / adaptation
Authorization gate	Retain and strengthen	Use renewable, time-bounded approvals tied to a signed scope version; continuous testing is not unlimited permission.
RoE and scope	Modify	Add asset tags, approved recurring windows, test-rate profiles and automatic expiry on ownership or environment changes.
Legal/privacy review	Strengthen	Data classification and privacy involving impact review before any engagement
		personal data or external assessors.
Threat classification	Retain	Add supplier/third-party access and insider risk indicators; classify by evidence and behaviour.
Lab	Expand	Maintain isolated reusable images and resettable

		environments; use synthetic data by default.
Disclosure	Redesign for shorter timeline	Add severity-based response clocks, automated reminders, escalation and executive exception approval.
Document library External assessors	Automate Add assurance controls	Structured forms and stable IDs integrate approval, findings, remediation and disclosure. Identity verification, contract/NDA, least privilege, monitored access, evidence handling and access expiry.

11.3 New component – Continuous Assessment Control Register

Field	Purpose
Assessment profile ID	Defines approved recurring activity and its risk tier.
Asset group / owner	Exact systems covered; each asset remains owner-confirmed.
Authorized schedule	Specific windows and frequency; no indefinite blanket testing.
Allowed test profile	Named checks, rate limits, prohibited actions and safe configuration.
Data classification	Personal/sensitive data flag and privacy restrictions.
Assessor identity	Named internal/external personnel and access expiry.
Health guardrails Approval version Finding/disclosure SLA	Latency/error thresholds, monitoring contact and automatic stop trigger. Links to signed authorization and RoE hash. Severity-based acknowledgement,

	triage and remediation clock.

Review date / revocation Periodic recertification and immediate suspension on scope or risk change.

Integration: the control register references the authorization form and RoE; each run creates an activity log under the engagement/profile ID; findings are sent to the structured finding report; disclosure timers and escalations are managed by the disclosure layer. A change in asset owner, data class, tester, target or test method forces review before the next run.

11.4 Shorter disclosure timeline

Severity	Proposed acknowledgement	Triage / containment target	Escalation
Critical	Within 4 hours	Immediate containment assessment; same-day owner action plan.	CISO, incident response, legal/privacy and executive sponsor.
High	Within 1 business day	Triage within 2 business days; remediation plan within 3 business days.	CISO/programme owner if overdue.
Medium	Within 2 business days	Triage within 5 business days; remediation plan within 10 business days.	Department head if overdue.
Low	Within 5 business days	Triage within 10 business days; planned fix or documented acceptance.	Monthly governance review.

These are proposed internal service levels to satisfy the changed requirement, not legal deadlines. Active exploitation, confirmed data exposure or immediate risk requires incident-response procedures rather than waiting for ordinary disclosure clocks.

11.5 Remaining trade-offs and future improvements

- Speed versus assurance: continuous checks and external assessors increase coverage but can create approval workload. Risk-tiered routing and automation reduce delay, but high-risk activity still needs human review.
- Evidence detail versus privacy: richer proof improves reproducibility but may expose personal data. Use synthetic data, redaction, restricted evidence stores and minimum necessary proof.
- Central governance versus departmental ownership: central standards improve consistency, while local owners understand service risk. Keep central policy with local asset-owner sign-off.
- Future improvements: integrate asset inventory and identity lifecycle systems; add automated evidence redaction and deadline monitoring; conduct periodic independent audits of the programme.

11.6 Final defence

The final framework meets the scenario because it separates authorization, legality and appropriateness; maps threats to university assets; defines ethical decision rules; ties legal/privacy checks to controls; provides a complete RoE; uses coordinated disclosure; confines hands-on work to an isolated lab; and connects reusable documents through stable IDs. The walkthrough and test cases show how missing authorization, out-of-scope requests, privacy conflicts and delayed disclosure are handled. The scalability model identifies where central coordination and automation become necessary. The changed-requirement design adds recurring assessment

profiles and severity-based disclosure clocks without removing the authorization gate.

Conclusion

A university ethical-hacking programme must be governed as a controlled security-assessment process, not as informal tool use. The proposed framework
makes permission, scope, legal/privacy review, safe execution, evidence handling and responsible disclosure traceable from request to closure. Its central safeguard is that no test begins without current written authorization for the exact target and method. The isolated lab provides a safe setting for hands-on validation, while structured documents and continuous governance controls support future growth and external assessors.

References and Further Reading

● 1. Information Technology Act, 2000 (India), including Sections 43, 66, 72 and 72A. Consult the current official consolidated text and amendments. ● 2. Information Technology (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011, where applicable; verify current legal status and interaction with later data-protection legislation. ● 3. Digital Personal Data Protection Act, 2023 (India), and applicable rules/commencement notifications. Determine provisions in force on the engagement date.

● 4. United States Code, Title 18, Section 1030 – Computer Fraud and Abuse Act.

● 5. NIST Special Publication 800-115, Technical Guide to Information Security Testing and Assessment.

● 6. NIST Cybersecurity Framework 2.0, for governance, roles, risk management and continuous improvement.

- 7. FIRST, Common Vulnerability Scoring System (CVSS) documentation, for consistent vulnerability severity assessment.
- 8. ISO/IEC 27001 and ISO/IEC 27002, for information-security management and control guidance.
- 9. OWASP Web Security Testing Guide, for structured and safe web-application testing methodology.
- 10. Kali Linux documentation and the documentation for the selected virtualization platform, for isolated lab configuration.

Legal references are included as a study framework, not as a substitute for legal advice. Before real-world use, verify the latest official statutory text, amendments, rules, commencement dates and jurisdiction-specific requirements.

Final Submission Checklist

● All 11 tasks are addressed in the same order as the assignment brief. ● Authorization, legal compliance and ethical appropriateness are treated as separate gates.

● Every engagement uses a unique ID and versioned signed scope/RoE. ● Personal data is minimized, redacted and stored under controlled access. ● Lab uses a host-only network and is not bridged to the campus network. ● Four reusable documents and valid/boundary/invalid test entries are included. ● Walkthrough, systematic tests and refinement actions are documented. ● Scalability figures are labelled as assumptions until replaced with measured pilot data.

- Current legal text and commencement status are checked by university counsel before real engagement.